

Defense By Design: How To Dampen DDoS Attacks With A Resilient Network



Sep 14, 2017, 06:06pm EDT

Click to save this article.
You'll be asked to sign into your Forbes
account.
Got it

This article appears in [Security On The Internet](#), an in-depth report on cyberthreats and how executives can stop them.

The history of distributed denial-of-service (DDoS) attacks is replete with diabolical innovation and creativity — and they continue to shift in shape and method, bedeviling attempts to prevent them.

No one can create 100 percent effective protection against DDoS attacks. But chief information officers (CIOs), chief information security officers (CISOs) and the specialists on their teams do have effective ways to prepare for, react to and recover from DDoS attacks by assessing risk within the organization and building a resilient network to match — one that combines architecture and procedures to limit the possibility and effects of systemic failure.

A DDoS attack can be defined by its goal: slowing down or stopping business activity by hindering digital responsiveness. Attackers use multiple pirated systems to target a single system and flood it with traffic from many directions.

Such attacks can affect application layers, or pile on fake data requests, or overwhelm a system with junk data. They can also trick one part of a system to overwhelm another part with data requests.



Even a brief outage or slowdown can harm revenue, customer service and reputation. ISTOCK

“A DDoS attack can also act as a smokescreen for other attacks happening simultaneously, including web application attacks that steal sensitive data,” said John Summers, enterprise vice president and general manager at Akamai Technologies.

The Next Attack

The huge Mirai botnet attack of October 2016 was unlike anything anybody had ever seen — roughly half a million devices, including DVRs and webcams, turned into an attacking army of “bots.”

Such a giant attack is not something that will happen every day, according to Eugene Spafford, executive director emeritus of the Center for Education and Research in Information Assurance and Security at Purdue University. “But there will be further

attacks at large scale — maybe they won't be common or regular, but they will occur," he said.

The expanding "attack surface" of the Internet of Things (IoT) will play a central role in these future actions. "As we have more and more users and more things online, and attackers have the ability to subvert large quantities of them and turn them into things like a botnet, DDoS attacks are only going to grow," Spafford said.

He pointed out that, to date, most known DDoS attacks have been of relatively short duration, for a variety of reasons, so not every attack called for significant resilience, but could be met with patience. "I'm not sure, going forward, how much that will continue to be the case," he said.

Even a brief outage or slowdown can harm revenue, customer service and reputation. And an attack on one enterprise can damage the entire business stream. For example, a DDoS attack on a shipper means packages pile up in ports. Products don't arrive at retail or distribution outlets. Downstream customers look elsewhere, and merchants lose money over a problem that isn't theirs directly.

Assessing The Risks

Cybersecurity researcher Wendy Nather, principal security strategist at Duo Security, said not every business has to prepare for an attack of the size or sophistication of a giant botnet attack. Rather, every business must assess its particular risk and "dig into threat intelligence to find out who might be motivated to attack them and what types of attacks might be used," she said.

A smaller operation, such as an independent retail outfit, does not need to protect itself the way a bank does, according to Nather, who previously led regional security at a major bank in Europe.

To be prepared, a CISO should first assess the size and nature of a company's risk profile in its primary market, and then create a plan for countering the most anticipated types of DDoS attacks.

Risks are often specific to industries and their regulations, which differ by country or region. Spafford pointed to numerous examples of the regulatory impact on business resilience. Nuclear power plant operations are required to have the computing ability necessary to resist unauthorized changes to code. The medical industry must have networks capable of ensuring confidentiality of records. The financial industry must maintain and store its data securely so that it can be audited properly.

There's no cookie-cutter approach to regulations, according to Spafford. "You need to know your business's context in the regulatory environment," he said.

Architecting For Resilience

Network architecture provides the foundation for resilience. What an organization wants to avoid is operating with a completely flat network — that is, a network that shares bandwidth across its architecture, making every part of the system available. Attacking one part can open up access to everything. "Good security practice says to partition your network," said Spafford.

An organization should, in other words, be able to wall off the different sections of its network to prevent the spread of any kind of attack. The tricky part is factoring this in as a network is built or expanded, when creating connectivity between different sections is desired or necessary, but poses a risk.

From an architectural standpoint, a resilient network should also have redundancy in a large number of its components and the ability to reroute traffic from one set of equipment to another if necessary, according to Nather.

If a network depends on high-volume traffic among different application tiers — for example, several complex websites — there shouldn't be just one database on the back end, she said.

Nather highlighted two key tactics: A resilient network should have multiple points of control where administrators can log in and make changes. And it should not rely on a sole Internet service provider but rather have multiple points of potential access through different providers.

Preparing For Attack

Creating a set of procedures to address an attack can't cover every variable under the sun, especially given how creative DDoS attacks can be. But having an established protocol, documented in a "runbook," can go a long way to clarifying who does what in the event of an attack.

In creating an attack procedure, an organization needs to designate who has the job of monitoring incoming traffic for potential attack patterns and ensure that those staff members have the ability to report their findings to the correct people up the organization's hierarchy, according to Nather.

In the event of a real attack, "you need to know how to include top management and people from legal and PR, and businesspeople," Nather said. "You might want to involve law enforcement."

System operators, Spafford said, should know ahead of time how to jam or shut off a system's major incoming connections, then go through the process of re-establishing the required service connections.

As far as attack rehearsals go, "successful companies do practice these on a regular basis," Nather said. Depending upon the particular attack scenario, representatives from the company's business and tech units should gather, on a conference call or in a meeting, to work through everyone's role and reaction to a DDoS attack.

"The act of practicing is like building up a muscle," Nather said.

Resilience In Action

When an attack does happen — and a business is prepared enough that it isn't taken totally off guard — the essential reaction is responding with greater bandwidth and more machine power at a moment's notice. "If I've got more bandwidth and machines than what I'm being attacked with, then that's the solution," Spafford said.

That infrastructure can be in the cloud. "Even the largest organizations don't have the capacity to repel the largest attacks," cautioned Summers. "The only way to ensure

resiliency is with a cloud layer of on-demand and highly scalable capacity.”

An organization must also have the agility to change IP addresses, domain names and routing so that, depending upon the nature of the attack, the targeted system can move to different addresses and to different hardware, Spafford said.

And don’t ignore the quality of the domain name system (DNS) you use. The default DNS that comes with your service provider might not present the capacity needed when under attack. When possible, use backup DNS providers so you can switch if your main one suffers a DDoS attack that affects your business.

Sometimes an organization can “black hole” an attack. That is, channel the attack traffic in a way that the attacker thinks the traffic is going to the intended target, but it is actually sent into a controlled space where it can be analyzed.

Then, if you have the technologists on your company’s team or can access them through a third-party ally, you could do real-time forensic analysis to find and take advantage of a weakness in the attack application itself, according to Nather, and hurt or kill its functionality.

Post-Action Review

Once an attack is beaten back, Spafford recommends a post-action review that asks:

- Did we detect the attack soon enough?
- Did we take proper steps to continue services that our company deems critical?
- Did our response work?
- Were there aspects of the attack that we missed?
- Are there any kinds of aftereffects that we missed?

Share the post-action review information with those partners and allies who should see it, such as your DDoS protection service or a security consultancy. And if an ally “provided you with information before or during the attack, did you use it adequately?” Spafford said.

Benefits of Resilience

Resilience affects the business bottom line, according to Summers. “Effectively resisting a DDoS attack means less downtime, and that translates to uninterrupted customer service and business operations, and less risk of lost revenue,” he said.

Resilience lets you live up to your promise of a quality customer experience. Your customers can find what they want quickly, buy it and go about their business. In an age of digital-native customers who expect optimal e-commerce performance, even a minor slowdown can hurt business.

Finally, a capably resilient network can keep your business’s name from appearing on the list of the latest DDoS victims. If your reputation depends on your ability to continue operations and communications, Spafford said, then you need a network that can defeat or neutralize the effects of an attack.

Scott Bowen is a freelance writer and editor who has written for True/Slant.com and Fortune Small Business. His fiction has been anthologized in Tight Lines: Ten Years of the Yale Anglers' Journal.



As the world's largest and most trusted cloud delivery platform, Akamai makes it easier for its customers to provide the best and most... **Read More**

Editorial Standards

Forbes Accolades
